

TrustBench: Can Language Models Audit Security Compliance?

Varun Gurnaney

May 2026

Abstract

We introduce TrustBench, a benchmark for evaluating large language models on security compliance auditing. The benchmark presents models with synthetic audit evidence containing planted compliance gaps across 20 tasks and 8 SOC 2 controls at five difficulty levels. D4-D5 tasks (75% of the benchmark) test red herring filtering, noise document handling, and professional judgment -- skills that go beyond gap detection into the materiality assessments that define real audit work. We evaluate 6 models from Anthropic and OpenAI (120 total runs). Claude Sonnet 4.6 leads at 82%, followed by Opus 4.7 (72%) and GPT-5.5 (71%). Three judgment tasks average below 28% across all models. We find that (1) recall is easy but precision separates models, (2) F1 scoring systematically penalizes thorough models that report legitimate extra findings, and (3) no model dominates across all compliance domains. The schema is framework-agnostic and extensible to ISO 27001, HIPAA, and PCI-DSS. Code, tasks, and results are open-source.

1. Introduction

Security compliance is a \$30B+ market built on manual labor. A SOC 2 Type II audit requires reviewing hundreds of documents -- access control policies, IAM credential reports, change management logs, termination records, backup execution logs, vendor assessments -- to determine whether controls are operating effectively over an observation period. This work is document-heavy, cross-referential, and requires professional judgment on materiality.

GRC teams have rapidly adopted LLMs for compliance work: evidence review, gap analysis, control mapping, security questionnaire responses. Every AI compliance vendor claims automation. Yet there is no standardized way to measure whether these tools produce accurate results. When a model reviews an access control policy and an IAM credential report, does it catch the service account with an expired key rotation? Does it notice that the Okta MFA default policy allows unauthenticated fallback? Does it check the exception register before flagging a vendor without a SOC 2 report?

No existing benchmark answers these questions. AIReg-Bench (Sherborne et al., 2025) tests LLMs against 120 EU AI Act samples -- a single regulation, single document type, proof-of-concept scale. LegalBench (Guha et al., 2023) tests legal reasoning but not multi-document evidence review. CUAD (Hendrycks et al., 2021) tests contract clause extraction. SWE-bench (Jimenez et al., 2024) and CyberGym (Wang et al., 2025) evaluate software engineering and cybersecurity capabilities, respectively. None test the core compliance audit workflow: cross-referencing multiple evidence types, validating exceptions, and making materiality judgments.

We introduce TrustBench to fill this gap. Our contributions are: (1) a benchmark with 20 tasks across 8 SOC 2 controls at 5 difficulty levels, (2) a framework-agnostic task schema supporting any control-based compliance standard, (3) a scoring methodology that captures both detection and precision using F1 with red herring handling, and (4) an evaluation of 6 frontier models with analysis of where and why they succeed or fail.

2. The TrustBench Benchmark

2.1 Problem Formulation

Given a compliance control C and an evidence package $E = \{e_1, \dots, e_n\}$ containing documents of mixed types (policies, configurations, logs, exception registers, noise), the task is to produce a set of findings F that identifies all genuine compliance gaps while avoiding false positives from documented exceptions and irrelevant evidence.

This formulation captures the core compliance audit workflow. Unlike code generation (SWE-bench) where the output is a patch verified by tests, or CTF challenges (CyBench) where the output is a flag string, compliance findings are narrative assessments with inherent subjectivity. Our scoring addresses this through keyword-based detection with calibrated thresholds.

2.2 Task Construction

Each task was constructed through a three-step process:

- Evidence authoring: Synthetic documents modeled on real audit artifacts. Each evidence file uses formats auditors actually encounter -- markdown policies, JSON configurations (IAM, MFA, firewall rules), CSV operational logs (termination records, access reviews, backup logs), and exception registers with compensating controls.
- Gap planting: Compliance deficiencies inserted into the evidence based on the control failures most commonly observed in real SOC 2 audits -- vague termination SLAs, MFA coverage gaps, stale service account credentials, CAB quorum failures, expired vendor exceptions, risk register staleness.
- Validation: Each task was spot-tested against at least one model to verify (a) all planted gaps are detectable from the provided evidence, (b) detection keywords trigger correctly across varied phrasing, and (c) red herrings are non-trivially distinguishable from real gaps.



Figure 1: Dataset statistics. Left: findings per task (gaps and red herrings). Center: documents per task (evidence and noise). Right: tasks by difficulty level. D4-D5 tasks dominate (75%).

2.3 Difficulty Levels

Tasks are organized into five difficulty levels, each testing a progressively harder audit skill:

D1 -- Detection (2 tasks). A single policy document with an obvious gap. Example: a change management policy states "changes are deployed by the requesting engineer" -- a clear segregation of duties violation. The model reads one document and identifies gaps. All 6 models score 88-100% at this level.

D2 -- Careful Reading (1 task). A single document with a subtle gap buried in a table or timeline. Example: an incident response plan assigns 24/7 on-call coverage to P1 incidents but only business-hours triage to P2 -- which includes "unauthorized access to production." The gap is easy to miss when scanning.

D3 -- Cross-Referencing (2 tasks). Multiple documents that must be compared. Example: a policy prohibits direct IAM user accounts, but the IAM credential report shows a user with console access. The access review log only covers SSO users, meaning the direct IAM user was never reviewed. No single document contains the full finding.

D4 -- Red Herring Filtering (8 tasks). Evidence packages include exception registers and noise documents. Some apparent gaps have valid explanations. Example: a GCP service account has a manual key (violating the workload identity policy), but the exception register shows a current CISO-approved exception with compensating controls. Models that flag this without checking the exception register lose precision. Noise documents (BCP summaries, vendor risk assessments) are included to test selective reading.

D5 -- Materiality Judgment (7 tasks). Ambiguous scenarios where reasonable auditors would disagree. Example: a critical vendor had a security incident -- they met the 72-hour notification SLA and contained it in 48 hours, but could not confirm whether customer data was compromised for 3 weeks. Should customers have been notified during the uncertainty period? Does meeting the contractual SLA excuse the data exposure uncertainty? These questions have no single correct answer.

2.4 Evidence Types

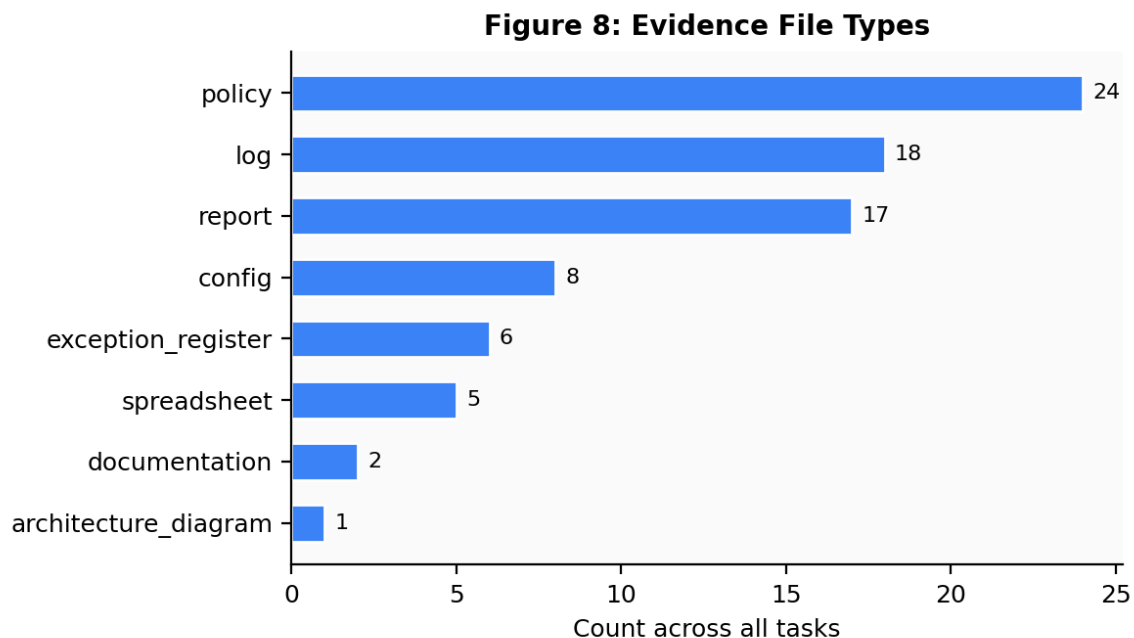


Figure 2: Distribution of evidence file types across all 20 tasks. Policies and CSV logs are the most common, reflecting real audit evidence composition.

2.5 Controls

The initial task set covers 8 SOC 2 Trust Service Criteria controls spanning security, availability, and risk management:

Control	Domain	Tasks	D4-D5
CC6.1	Logical Access	4	3
CC6.3	Data Access Authorization	2	1
CC6.6	System Boundaries	2	2
CC7.2	Monitoring	3	3
CC8.1	Change Management	3	3
CC3.1	Risk Assessment	2	2
CC9.1	Vendor Management	2	2

A1.2	Backup & Recovery	2	2
------	-------------------	---	---

Table 1: Controls covered. 20 tasks total, 15 at D4-D5.

3. Scoring Methodology

3.1 Detection Scoring (D1-D3)

For D1-D2 tasks, the score is recall: $\text{gaps_detected} / \text{total_gaps}$. For D3 tasks, we apply a precision penalty: $\text{score} = \text{recall} * \min(1, \text{max_expected_findings} / \text{model_findings_count})$. This penalizes models that report more findings than the planted ground truth warrants.

3.2 F1 Scoring (D4-D5)

For D4-D5 tasks, we compute the F1 score -- the harmonic mean of precision and recall:

$$\text{recall} = \text{true_positives} / (\text{true_positives} + \text{false_negatives})$$

$$\text{precision} = \text{true_positives} / (\text{true_positives} + \text{false_positives})$$

$$\text{F1} = 2 * \text{precision} * \text{recall} / (\text{precision} + \text{recall})$$

True positives are planted gaps correctly detected (matching $\geq N$ of K detection keywords). False negatives are planted gaps missed. False positives include (a) reported findings that do not match any planted gap, and (b) red herring findings flagged without exclusion keywords (e.g., "exception approved," "compensating control"). Models that mention a red herring topic but correctly dismiss it (matching exclusion keywords) are not penalized.

3.3 Limitations of Keyword Scoring

Keyword-based scoring is deterministic and reproducible but has known limitations. A model may detect a gap using language that does not match any keywords (false negative in scoring). Conversely, keywords may match incidentally from unrelated context (false positive in scoring). We calibrate keywords broadly (7-10 per finding, threshold 2-3) and use entity-specific terms rather than generic words. During development, we discovered that generic keywords ("freeze," "approved") produced scoring artifacts and replaced them with task-specific phrases.

4. Experimental Setup

We evaluate 6 models across all 20 tasks (120 total runs). Models receive the evidence package as multimodal message content (text blocks for documents, base64-encoded images for screenshots) with a system prompt instructing them to produce an audit assessment. Output is free-text -- we do not constrain format. Temperature is default for all models. Each task is run once per model.

Model	Provider	Type
Claude Sonnet 4.6	Anthropic	Mid-tier
Claude Opus 4.7	Anthropic	Frontier
Claude Haiku 4.5	Anthropic	Small
GPT-5.5	OpenAI	Frontier
GPT-4.1	OpenAI	Mid-tier
GPT-4o	OpenAI	Prior-gen

Table 2: Models evaluated.

5. Results

5.1 Overall Performance

#	Model	Provider	Score	Recall	Prec.	Finds/Task
1	Sonnet 4.6	Anthropic	82%	92%	63%	7.3
2	Opus 4.7	Anthropic	72%	94%	47%	9.6
3	GPT-5.5	OpenAI	71%	82%	50%	8.7
4	GPT-4.1	OpenAI	61%	71%	48%	6.8
5	Haiku 4.5	Anthropic	61%	90%	39%	14.6
6	GPT-4o	OpenAI	44%	55%	38%	7.2

Table 3: Overall performance. Score = avg per-task score (detection for D1-D3, F1 for D4-D5).

Figure 9: Score Distribution (120 runs)

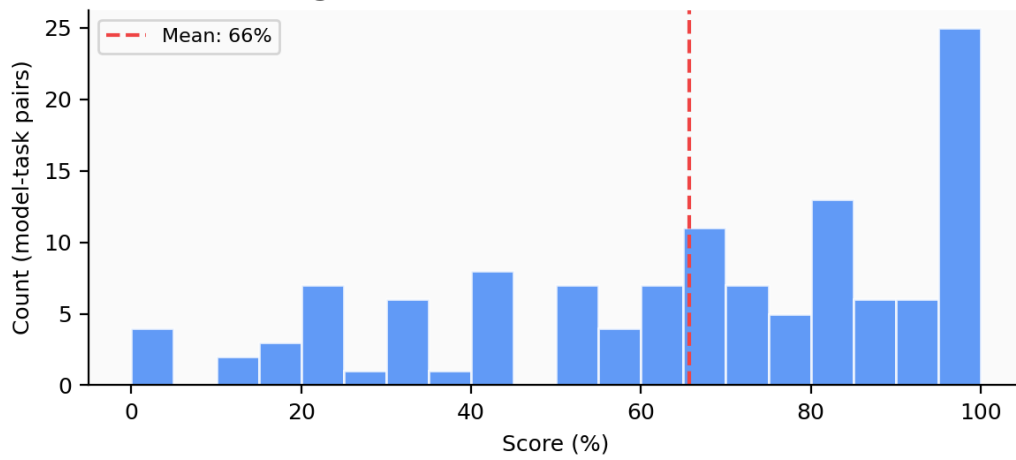


Figure 3: Score distribution across all 120 model-task runs. Bimodal pattern: models either solve a task well (70-100%) or struggle significantly (0-40%).

5.2 Performance by Difficulty

Figure 3: Score by Difficulty Level per Model

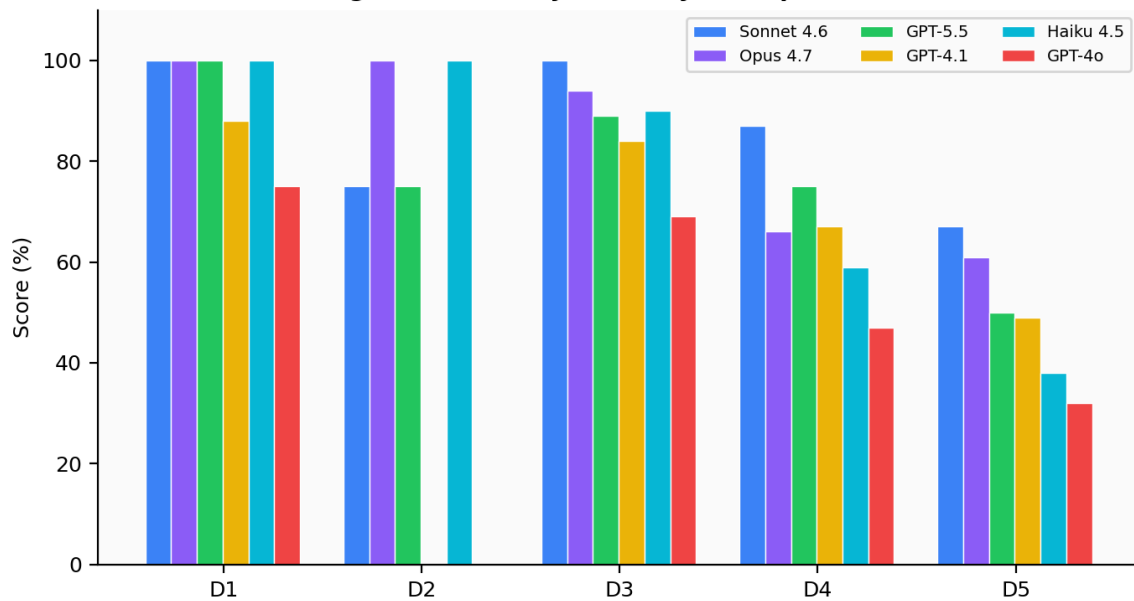


Figure 4: Score by difficulty per model. All models perform well on D1 (88-100%). Sharp divergence begins at D4 and deepens at D5. GPT-4.1 and GPT-4o score 0% on D2 due to missing a subtle gap.

5.3 Performance by Control Domain

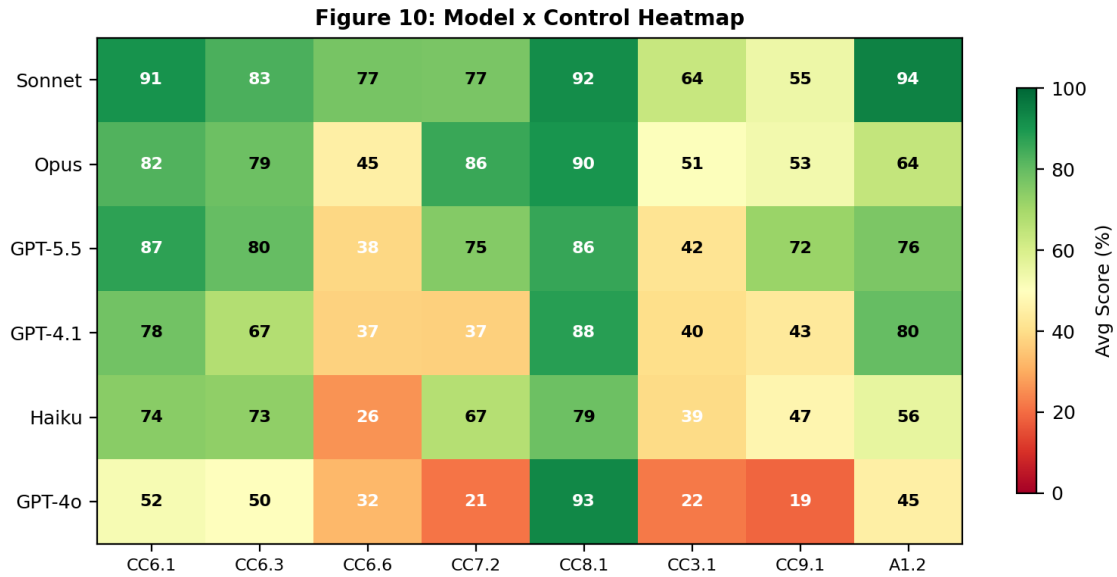


Figure 5: Model x Control heatmap. Change Management (CC8.1) is the easiest domain across all models. CC9.1 (Vendor Management) and CC3.1 (Risk Assessment) are consistently the hardest. CC6.6 (System Boundaries) shows the widest model variance.

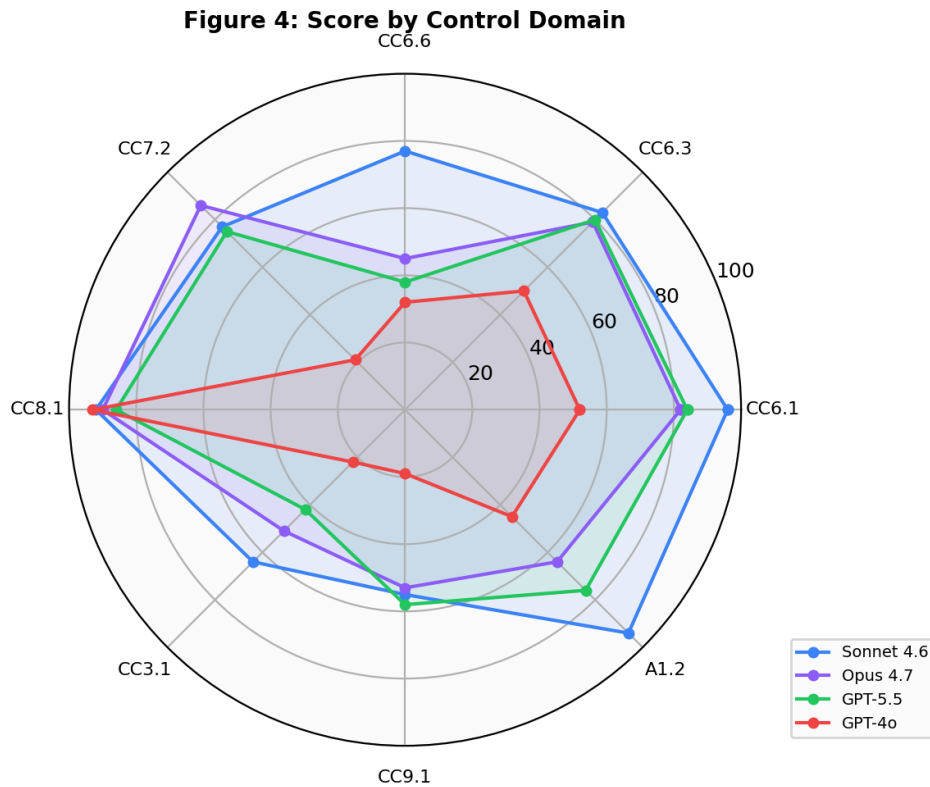


Figure 6: Radar plot of top 4 models by control domain. Each model has a distinct shape -- no single model dominates all domains. GPT-4o excels at Change Management (93%) but collapses on Monitoring (21%).

5.4 Recall vs Precision

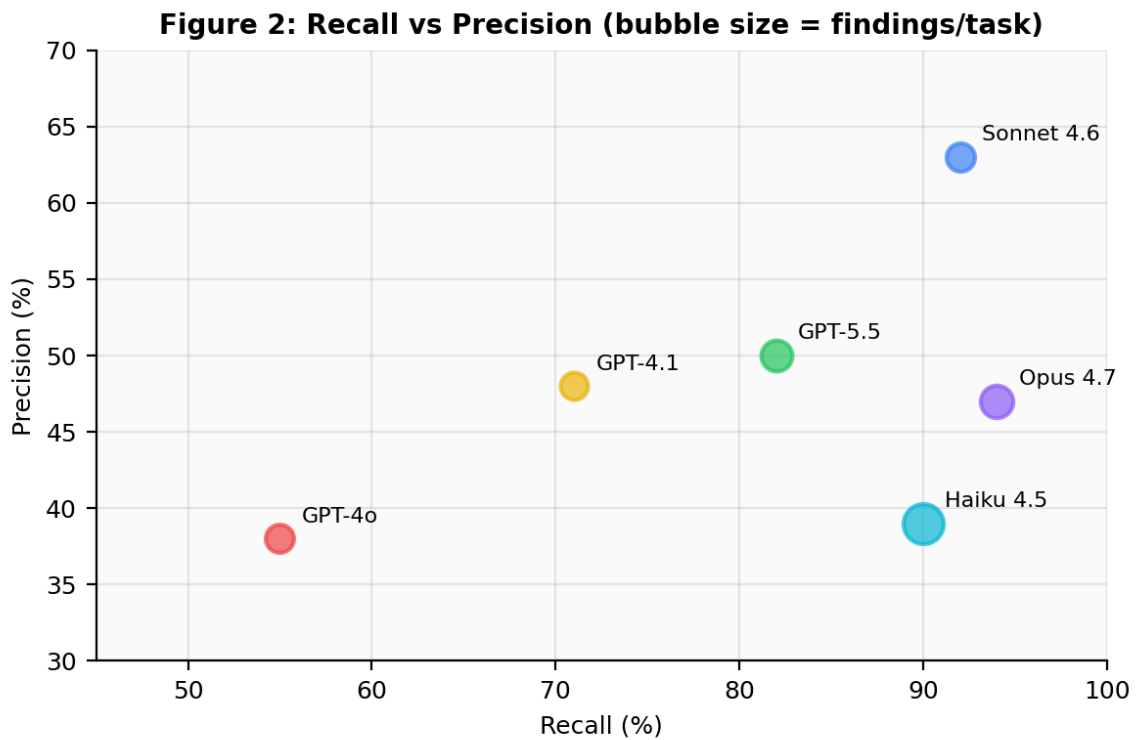


Figure 7: Recall vs Precision (bubble size = avg findings/task). Opus achieves the highest recall (94%) but lowest precision (47%). Haiku has the largest bubble (14.6 findings/task) -- high recall but extreme over-reporting.

5.5 D5 Judgment Tasks

The hardest tasks are D5 judgment scenarios. Three tasks average below 28%:

- cc3.1-5-001 (Risk Assessment, 23%): Risk downgrades without documented justification. 11-month-old annual assessment. SGC reviewed 10 of 22 risks. A risk with likelihood=2, impact=5 rated "Medium."
- cc9.1-5-001 (Vendor Mgmt, 24%): Vendor met 72-hour SLA but 3-week data exposure uncertainty. Qualified SOC 2 opinion acknowledged without risk assessment.
- cc6.6-5-001 (System Boundaries, 28%): Admin API bypasses gateway -- VPN-restricted, Q3 pentest accepted risk, 0.3% of traffic.

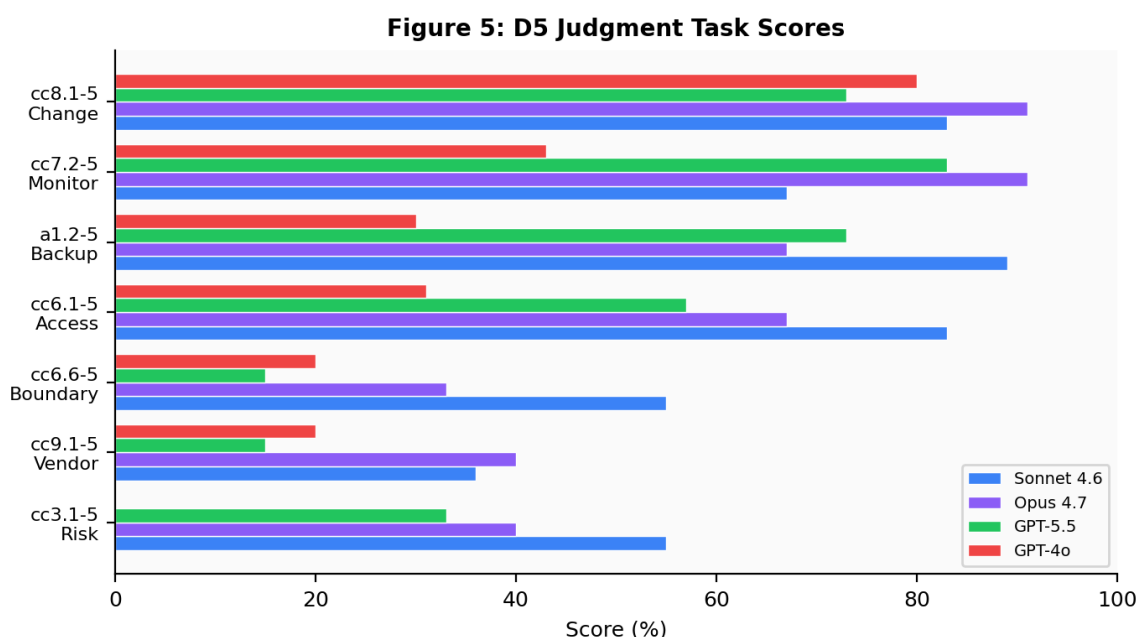


Figure 8: D5 task scores by model. No model scores above 40% on the three hardest tasks. Opus leads on Change Management (91%) and Monitoring (91%).

6. Analysis

6.1 The Over-Reporting Problem

The most significant finding is the tension between thoroughness and precision. Opus achieves 94% recall -- the highest of any model -- but reports 9.6 findings per task on average. Many extras are legitimate compliance observations: "emergency approval via Slack DM lacks audit trail," "standard change deployed outside maintenance window." These are findings a human auditor might include. Under F1 scoring, they count as false positives.

Sonnet leads because it balances both dimensions: 92% recall with only 7.3 findings per task. Its lead over Opus (82% vs 72%) is real but partly attributable to the scoring methodology. Under a scorer that credits legitimate extra findings, the gap would narrow.

This is not a flaw in the models -- it is a limitation of ground-truth benchmarking for open-ended tasks. Unlike code (test passes or fails) or CTFs (flag matches or does not), compliance findings exist on a spectrum of validity. A v2 scorer using LLM-as-judge could evaluate whether extra findings are legitimate, but introduces non-determinism and circular evaluation concerns.

6.2 Domain-Specific Capabilities

Model performance varies dramatically by compliance domain. Change Management (CC8.1) averages 88% across all models -- the evidence structure (change log CSV, policy, CAB minutes) maps well to LLM cross-referencing capabilities. Vendor Management (CC9.1) averages 46% -- it requires SOC 2-specific knowledge about inclusive vs carve-out report methodology and judgment about vendor incident response adequacy.

GPT-4o demonstrates the most extreme domain specificity: 93% on Change Management vs 19% on Vendor Management. This suggests that compliance capability is not a monolithic skill but a collection of domain-specific competencies.

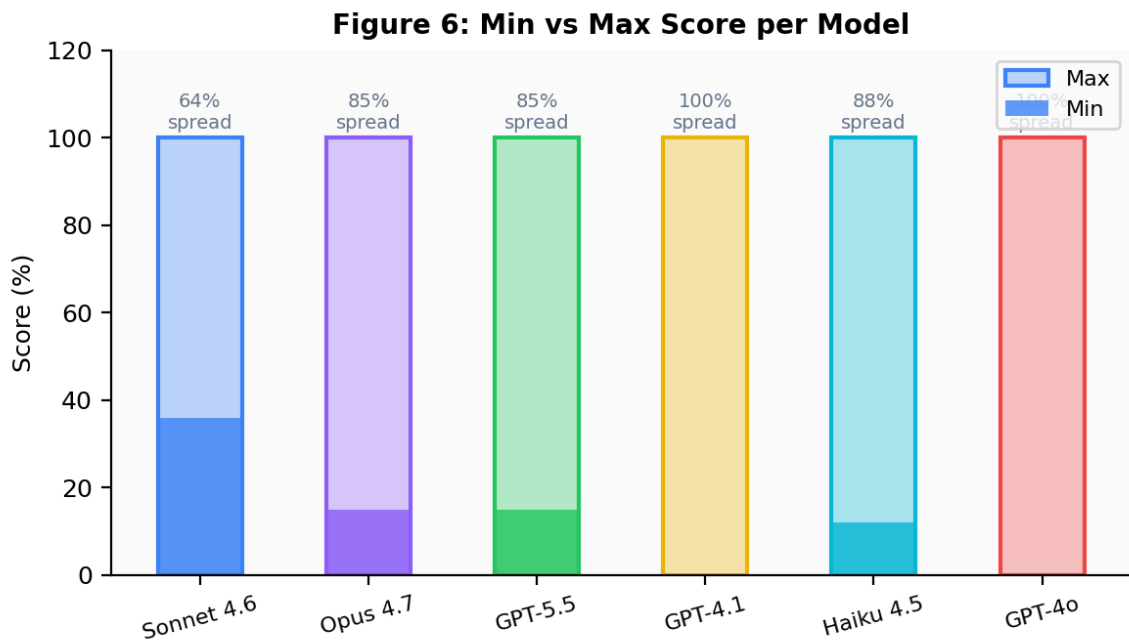


Figure 9: Score spread per model (max - min). Every model has at least one domain below 40%.

7. Limitations and Future Work

7.1 Current Limitations

- Scale: 20 tasks provides directional findings but lacks statistical power. Individual task scores have high variance across models.
- Scoring: Keyword matching cannot capture all valid phrasings and penalizes legitimate extra findings. The finding-count regex for precision estimation is a heuristic that may miscount non-standard response formats.
- Synthetic evidence: Documents are authored, not sourced from real audits. While modeled on actual artifacts, they may not capture the full complexity of production environments.
- Single framework: All tasks cover SOC 2. While the schema supports other frameworks, no ISO 27001, HIPAA, or PCI-DSS tasks exist.
- Single run: Non-deterministic model outputs mean scores may vary. We did not measure run-to-run variance.

7.2 Future Work

Task expansion. We target 64+ tasks (8 per control: 1 D1, 1 D2, 1 D3, 2 D4, 3 D5). The authoring guide and schema are designed for community contributions. Each task takes approximately 1-2 hours to author and validate.

Multi-framework support. ISO 27001 Annex A, HIPAA Security Rule, PCI-DSS v4.0, and NIST CSF 2.0 task sets require only authoring new tasks -- no changes to the evaluation harness, scoring, or CLI. We have open GitHub issues for each framework seeking contributors with domain expertise.

LLM-as-judge scoring. An optional secondary scorer that evaluates whether extra findings are legitimate compliance observations or noise. The primary keyword score remains for reproducibility. Open questions include which model to use as judge (circular evaluation concerns), handling judge non-determinism, and cost per evaluation run.

Expanded model coverage. Gemini models could not be benchmarked due to API quota limits. Open-source models (Llama, Mistral, Qwen) would require local inference setup. Reasoning models (o3, o4-mini) may perform differently on

D5 judgment tasks.

Scoring methodology research. The over-reporting penalty is the most significant limitation. Alternative approaches include: expanding ground truth to include common valid extra findings, implementing a "strict" vs "lenient" scoring mode, or using a panel of human auditors to grade model outputs as a gold standard.

8. Related Work

Code generation benchmarks. HumanEval (Chen et al., 2021) introduced function-level code generation evaluation. SWE-bench (Jimenez et al., 2024) raised the bar to real GitHub issues with test-suite verification. SWE-bench Pro (Scale AI, 2025) extended to 1,865 tasks across 41 repos with contamination resistance. TrustBench follows the SWE-bench pattern of structured tasks with deterministic evaluation, adapted for compliance rather than code.

Cybersecurity benchmarks. CyBench (Zhang et al., 2024) evaluates agents on 40 CTF challenges with subtask decomposition. CyberGym (Wang et al., 2025) uses 1,507 real CVEs with proof-of-concept exploit generation and dual verification (crash vulnerable, not crash patched). Both use Docker-based sandboxed environments. TrustBench is document-based (no Docker required), making it accessible to GRC teams without infrastructure.

Compliance and legal benchmarks. AIReg-Bench (Sherborne et al., 2025) is the closest prior work: 120 expert-annotated samples testing compliance with EU AI Act articles. LegalBench (Guha et al., 2023) tests legal reasoning across 162 tasks including rule-application. CUAD (Hendrycks et al., 2021) tests contract clause extraction across 510 contracts. None test multi-document compliance auditing with exception registers, red herrings, noise documents, and materiality judgment -- the skills that define real audit work.

General reasoning. GAIA (Mialon et al., 2023) tests multi-step reasoning with exact-match evaluation. GPQA (Rein et al., 2023) tests graduate-level domain knowledge. ARC-AGI (Chollet, 2024) tests novel generalization. TrustBench complements these by evaluating domain-specific professional judgment rather than general reasoning.

9. Conclusion

TrustBench demonstrates that LLMs can detect compliance gaps requiring cross-referencing multiple documents -- a capability with direct practical value for GRC teams. Frontier models achieve 82% average across 20 tasks, with near-perfect recall on detection and cross-referencing tasks.

However, three findings limit enthusiasm: (1) no model scores above 28% on materiality judgment tasks, indicating that professional compliance judgment remains beyond current capabilities; (2) models systematically over-report, with even the best model reporting 50% more findings than the ground truth; and (3) performance varies significantly by control domain, with no single model dominating across all areas of compliance.

The benchmark is early-stage and the scoring methodology has documented limitations around the over-reporting penalty. We view TrustBench as infrastructure for the compliance AI evaluation ecosystem, much as SWE-bench provided infrastructure for coding AI evaluation. The schema is designed to grow through community contributions across frameworks and controls.

Code, tasks, and results: github.com/varungurnaney/trustbench